

NORTHSTAR FINANCIAL SERVICES

DATA CLASSIFICATION, HANDLING & PRIVACY POLICY V3.2

DOCUMENT ID	EFFECTIVE DATE	POLICY OWNER	CLASSIFICATION
POL-DATA-2025-05	Sep 01, 2025	Chief Privacy Officer & Legal	Internal Restricted

1. PURPOSE & SCOPE

Northstar Financial Services (NFS) manages sensitive financial assets, proprietary market intelligence, and consumer Personally Identifiable Information (PII). This policy defines the mandatory classification taxonomy, handling standards, transmission rules, and privacy protection protocols that all third-party software and AI vendors must adhere to when interacting with NFS data assets.

2. FOUR-TIER DATA CLASSIFICATION TAXONOMY

All data generated, processed, stored, or transmitted within or across NFS environments must be classified into one of four distinct tiers governing encryption, access control, and routing constraints:

CLASSIFICATION TIER	DEFINITION & EXAMPLES	MANDATORY HANDLING & ENCRYPTION STANDARD
Tier 4: Highly Confidential	Customer PII, SSNs, bank account numbers, unreleased quarterly earnings, M&A plans, cryptographic keys.	AES-256 at rest (CMEK), TLS 1.3 in transit, strict RBAC, isolation to US/EU regions only.
Tier 3: Confidential	Internal audit reports, vendor contracts, employee data, proprietary risk models, security vulnerability logs.	Encrypted at rest and in transit; authorized internal personnel and approved vendors only.
Tier 2: Internal	Standard company policies, organizational charts, non-sensitive operational memos, internal training decks.	Internal network access; basic access controls; standard enterprise transport security.
Tier 1: Public	Public marketing collateral, published annual reports, press releases, public website content.	No special restriction required; integrity protection recommended.

3. PRIVACY REGULATIONS & CROSS-BORDER RESTRICTIONS

Vendors processing NFS data must comply with international privacy frameworks including GDPR, CCPA/CPRA, GLBA, and NYDFS 23 NYCRR 500:

- Data Subject Rights:** Vendors must support automated mechanisms for data subject access requests (DSAR), including rapid retrieval, rectification, and complete erasure upon verified request.
- Cross-Border Transfer Prohibition:** Transfer of Tier 4 (Highly Confidential) data outside approved US or EU jurisdiction zones requires prior written authorization from the NFS Chief Privacy Officer.

Privacy Mandate: Any third-party software or AI tool that commingles Tier 4 customer PII across multi-tenant unsegmented databases without cryptographic tokenization or field-level masking will fail compliance evaluation.

4. AI PROMPT SANITIZATION & PII REDACTION

When third-party large language models or deep agent systems are utilized for analysis, text summarization, or contract review, strict data masking safeguards must be enforced:

DATA ELEMENT	INBOUND PROCESSING RULE	ENFORCEMENT MECHANISM
Raw Customer PII	Must be tokenized, pseudonymized, or scrubbed prior to dispatching queries to external APIs.	NFS Enterprise Gateway Proxy / Data Loss Prevention (DLP) filter.
Financial Account IDs	Masked to display only last 4 digits (e.g., `***-1234`) in logs and model context windows.	Regex masking applied at the MCP retrieval layer.
Proprietary Trade Secrets	Tagged with classification metadata; blocked from public-facing foundational models.	Policy-driven metadata routing rules in Deep Orchestrator.

5. DATA CLASSIFICATION RED-LINES & VETO CRITERIA

The Legal & Compliance Agent enforces strict red-lines regarding data ownership and privacy compliance:

VETO Vendor Data Ownership Claims Vendor agreement asserts ownership, secondary usage rights, or intellectual property rights over processed NFS data or derivative insights.	VETO Unencrypted Storage of PII Storing Tier 4 Highly Confidential PII in plaintext or utilizing weak cryptographic standards (e.g., MD5, SHA-1, AES-128 without salt).
REQUIRED Data Portability Guarantee Vendor must provide data export in structured, machine-readable formats (JSON, CSV, Parquet) within 7 days of contract termination request.	REQUIRED Breach Notification SLA Immediate notification to NFS Privacy Team within 24 hours of any unauthorized exposure or data exfiltration incident.

6. AUDIT & COMPLIANCE VERIFICATION

Compliance with data classification and privacy standards is verified during each vendor assessment:

- Artifact Inspection:** The Legal and Compliance Agent matches vendor data flow diagrams against the four-tier classification matrix.
- Defensible Audit Log:** All classification mappings and routing decisions are written to the immutable audit trail for regulatory inspection.